

Chương 7. Xác thực 2 yếu tố với Blockchain

Mục tiêu bài học

- Hiểu được khái niệm xác thực 2 yếu tố (Two-Factor Authenticaion - 2FA).
- Hiểu được cách ứng dụng Blockchain trong việc xác thực 2 yếu tố 2FA.

Nội dung bài học

- Khái niệm xác thực 2 yếu tố (Two-Factor Authenticaion - 2FA).
- Blockchain cho xác thực 2 yếu tố 2FA.

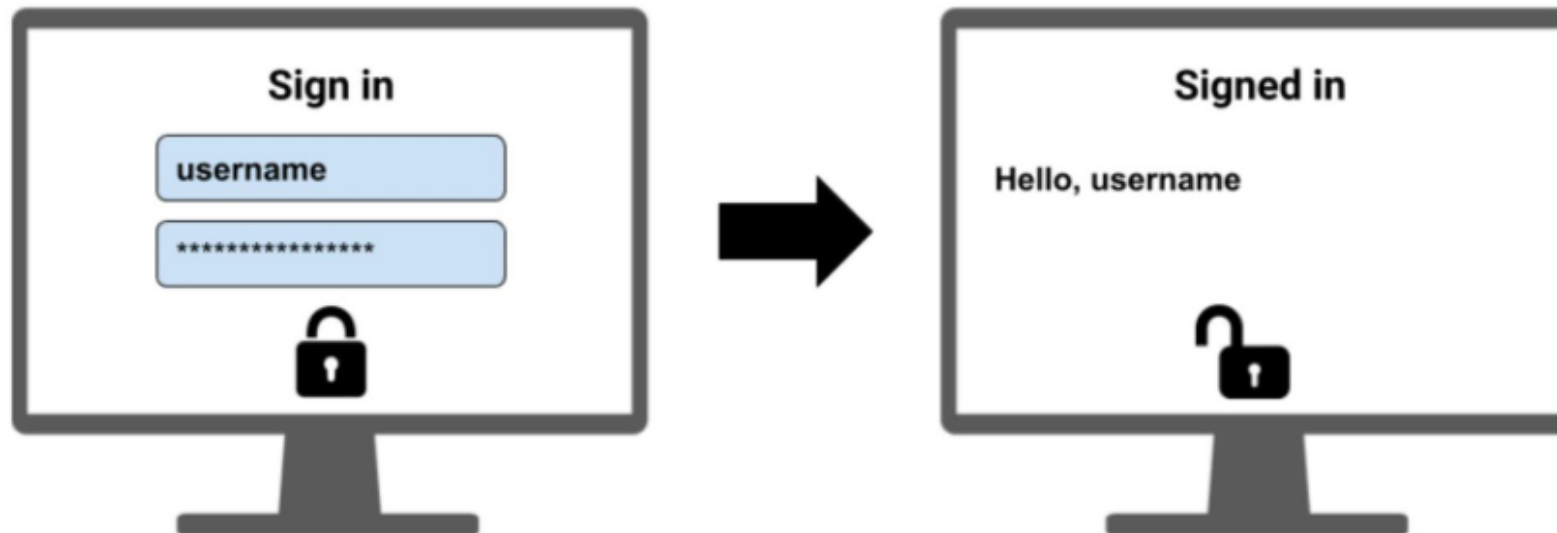
1. Khái niệm xác thực 2 yếu tố (Two-Factor Authenticaion - 2FA)

- Đôi khi, tin tặc có thể dễ dàng đoán mật khẩu của người dùng dựa trên hoạt động hàng ngày, hành vi hoặc tên của họ.
- 2FA là lớp bảo mật bổ sung được sử dụng để đảm bảo rằng chỉ chủ sở hữu hợp lệ mới có thể truy cập tài khoản của họ, bao gồm một trong các biểu mẫu sau:
 - **Điều mà người dùng biết:** có thể là thông tin như mật khẩu, câu trả lời cho câu hỏi bí mật hoặc có thể là số nhận dạng cá nhân (PIN).
 - **Thông tin mà người dùng có:** bao gồm mức độ xác thực thứ hai dựa trên chi tiết thẻ, thông qua điện thoại thông minh, phần cứng khác hoặc mã thông báo phần mềm.
 - **Thông tin mà người dùng là:** là một trong những cách hiệu quả nhất, được thực hiện với dữ liệu sinh trắc học như tổ hợp khóa động và thao tác chuột.

1.1. Sự phát triển của xác thực người dùng

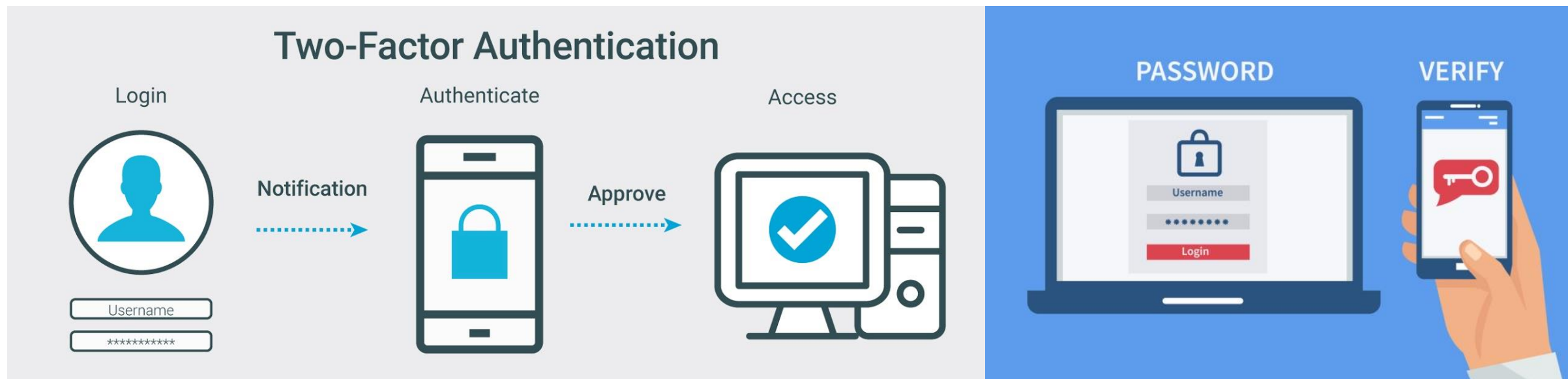
- Một số giải pháp xác thực bổ sung an toàn cho hệ thống:
 - **SFA (Single-Factor Authentication):** dựa trên thông tin được chia sẻ trước của người dùng: mã PIN, mật khẩu hoặc có thể là câu hỏi bảo mật. Tuy nhiên, người dùng có thể quên thông tin này nếu họ không thường xuyên truy cập ứng dụng.

Single-Factor Authentication



1.1. Sự phát triển của xác thực người dùng

- Một số giải pháp xác thực bổ sung an toàn cho hệ thống:
 - **2FA (Two-Factor Authentication):** khắc phục vấn đề quên thông tin được chia sẻ trước của người dùng, bằng cách sử dụng smartphone, thẻ khóa hoặc xác minh mật khẩu một lần (OTP). Người dùng không phải chia sẻ bất cứ điều gì với chủ sở hữu ứng dụng, giúp tránh được nguy cơ tài khoản bị chiếm dụng do thông tin đăng nhập bị đánh cắp.



1.1. Sự phát triển của xác thực người dùng

- Một số giải pháp xác thực bổ sung an toàn cho hệ thống:
 - **MFA (Multi-Factor Authentication):** xác thực người dùng ở cấp độ thứ hai, như sinh trắc học bằng giọng nói, nhận dạng khuôn mặt, hình học tay, quét võng mạc mắt, quét vân tay, vị trí địa lý, nhận dạng hình ảnh nhiệt và nhiều phương pháp khác.



Step 1
Username and
password entered



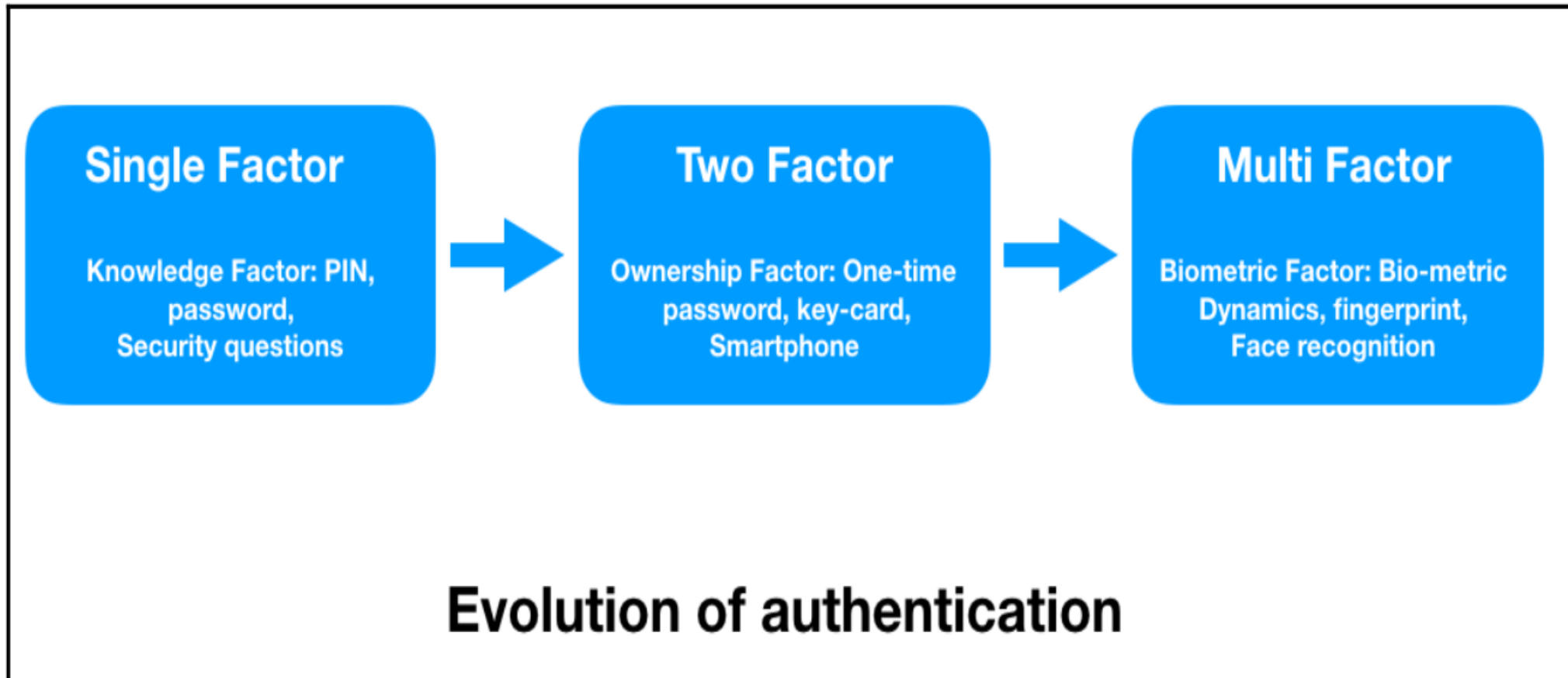
Step 2
Token or PIN entered



Step 3
Fingerprint or other
biometric verified

1.1. Sự phát triển của xác thực người dùng

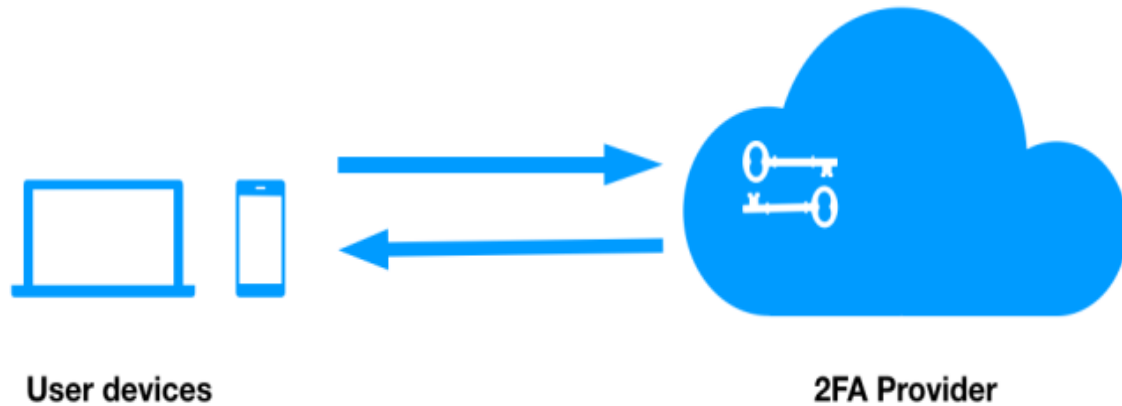
- Sơ đồ minh họa sự phát triển của xác thực:



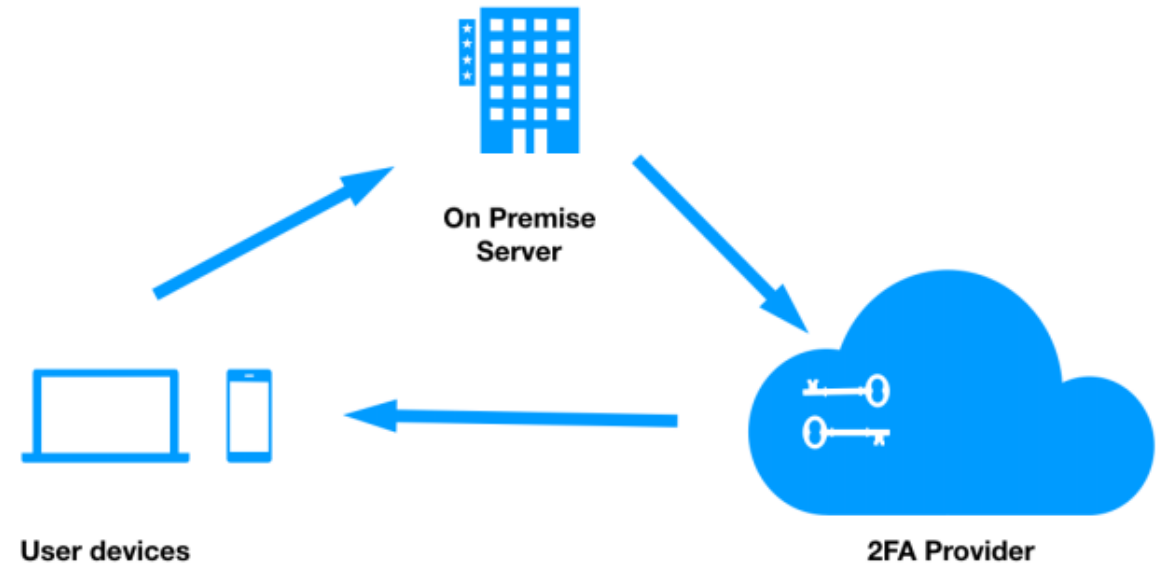
1.2. Tại sao chọn 2FA?

- 2FA giúp bảo mật cho cả người dùng cuối và doanh nghiệp, với các lợi ích như sau:
 - **Bảo mật tốt hơn:** OTP dựa trên SMS giúp giảm nguy cơ mạo danh người dùng, trộm cắp tài khoản và xâm nhập dữ liệu. Dù tin tặc có được thông tin đăng nhập của người dùng từ các trang web đen, họ vẫn không có thông tin thứ hai cần thiết để hoàn thành xác thực.
 - **Tăng năng suất:** Mobile 2FA giúp các DN sử dụng mức xác thực thứ hai một cách liên tục. Nhân viên có thể truy cập các ứng dụng, tài liệu và hệ thống của bên thứ ba một cách an toàn từ bất kỳ thiết bị hoặc vị trí nào mà không cần chia sẻ bất kỳ thông tin bí mật nào.
 - **Giảm sự lừa đảo và tăng sự tin cậy:** giảm thiểu sự lừa đảo trong giao dịch, ngay cả khi các trang web thương mại không chịu trách nhiệm về xâm nhập dữ liệu.

1.3. Nguyên lý hoạt động của 2FA



Cloud-based 2FA



On Premise 2FA

1.3. Nguyên lý hoạt động của 2FA

- 2FA có thể được triển khai ở hai chế độ:
 - **Giải pháp dựa trên cloud:** được sử dụng nhiều bởi thương mại điện tử, ngân hàng trực tuyến và các ứng dụng web liên quan đến dịch vụ trực tuyến khác.
 - **Giải pháp cục bộ:** một số tổ chức ưa thích các giải pháp cục bộ, trong đó nhân viên truy cập các ứng dụng web kết hợp tên người dùng và mật khẩu.
 - ✓ Thông tin được chuyển đến hệ thống tích hợp VPN nội bộ để xử lý thông tin đăng nhập và trao đổi khóa giữa các tổ chức và nhà cung cấp 2FA bên thứ ba.
 - ✓ Nhà cung cấp 2FA bên thứ ba sẽ tạo OTP và chia sẻ thông tin này với nhân viên qua SMS hoặc thông qua các ứng dụng di động.
 - ✓ Mô hình này giúp thiết lập được quyền riêng tư cho tổ chức, vì nó không phải chia sẻ thông tin đăng nhập với nhà cung cấp 2FA bên thứ ba.

1.4. Các thách thức của 2FA

- Trong 2FA, cấp độ xác thực đầu tiên là sự kết hợp của tên người dùng và mật khẩu, nhưng đối với cấp độ xác thực thứ hai, phần thông tin này được cung cấp từ kho lưu trữ trung tâm.
- Kho lưu trữ trung tâm chịu trách nhiệm lưu trữ tất cả thông tin cần thiết để xác thực người dùng.
- Mặc dù 2FA làm tăng mức độ bảo mật với lớp xác thực thứ hai, nó vẫn gặp phải nhược điểm của việc lưu trữ bảo mật CSDL tập trung danh sách thông tin người dùng.
- Cơ sở dữ liệu trung tâm có thể bị giả mạo hoặc bị phá hủy bởi các tin tặc có chủ đích và điều này có thể dẫn đến việc xâm nhập dữ liệu lớn.

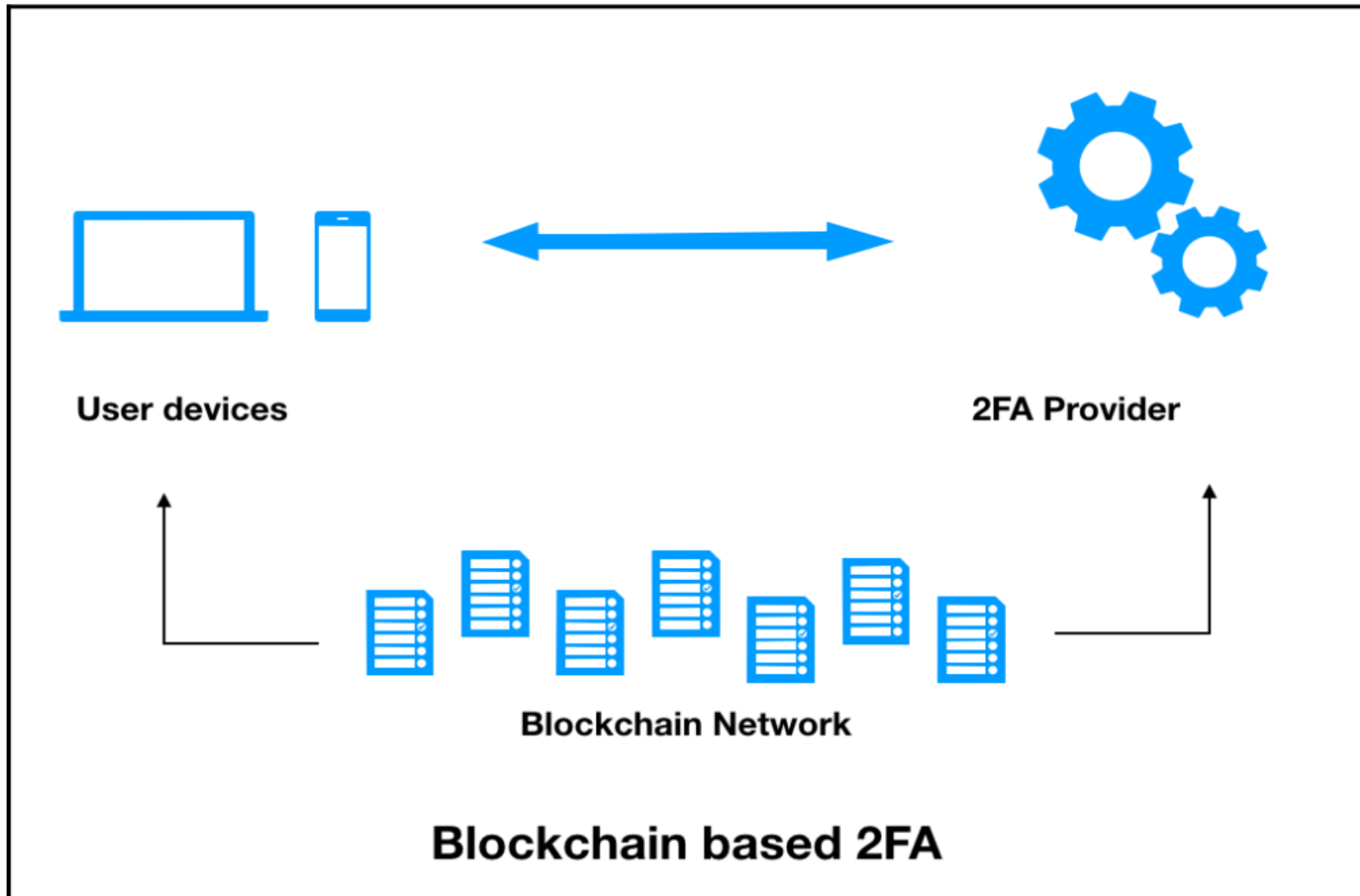
2. Blockchain cho xác thực 2 yếu tố 2FA

- Blockchain đã và đang phá vỡ nguyên tắc bộ ba bảo mật CIA dựa trên các giải pháp an ninh mạng.
- 2FA là một trong các giải pháp an ninh quan trọng trong nhiều năm; tuy nhiên, những kẻ tấn công đôi khi vẫn có thể xâm nhập thành công các hệ thống này.
- Chúng ta cần tìm hiểu cách thức Blockchain có thể chuyển đổi hệ thống 2FA để thiết lập được một phương pháp bảo mật cải tiến.

2.1. Blockchain có thể biến đổi 2FA như thế nào

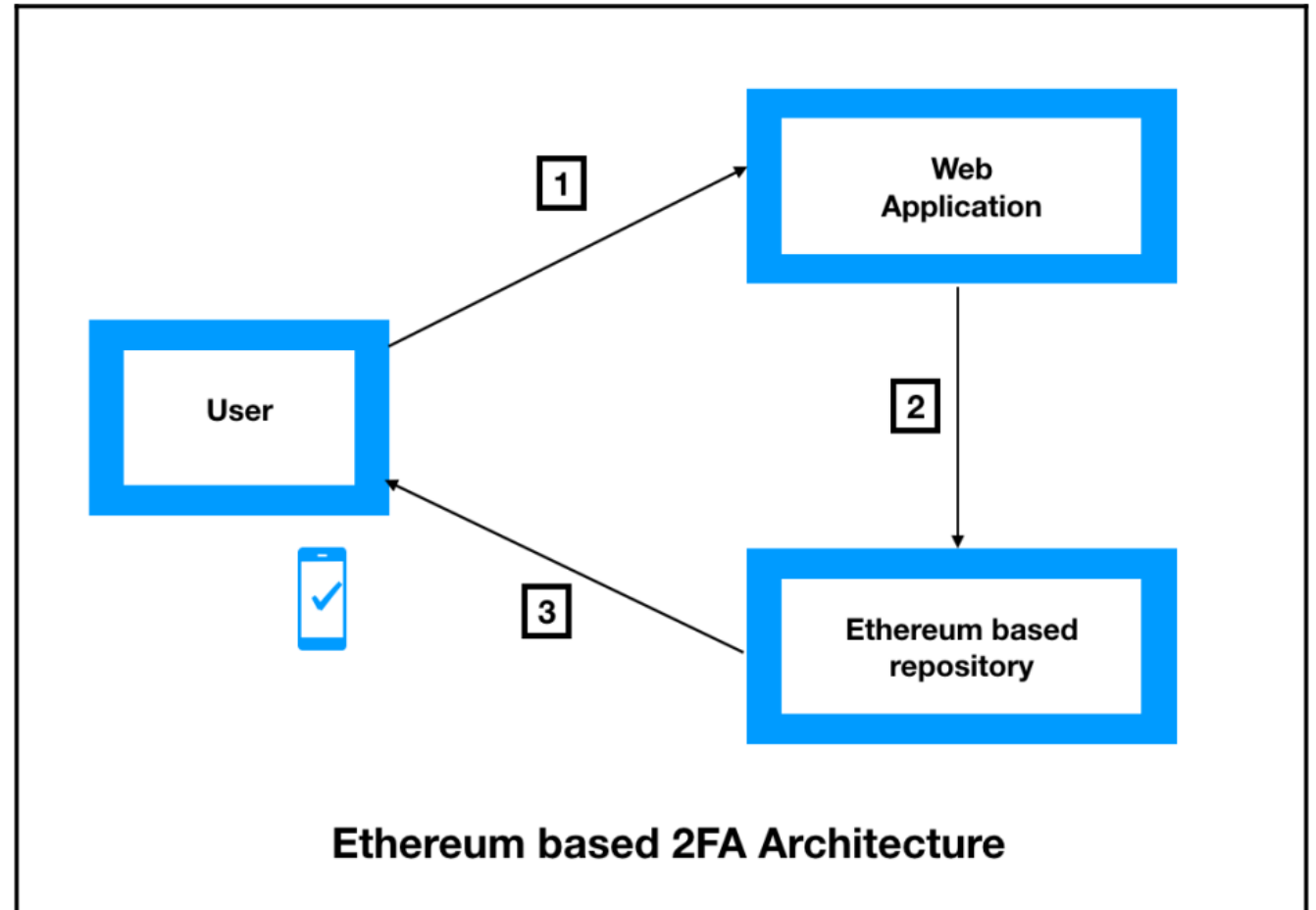
- Với Blockchain, chúng ta có thể đảm bảo rằng thông tin nhạy cảm có thể nằm trong các nút Blockchain có tính toàn vẹn và không thể sửa đổi hoặc xóa.
- Các thiết bị người dùng sẽ được xác thực bởi nhà cung cấp 2FA bên thứ ba thông qua mạng Blockchain.
- Mỗi mạng Blockchain nội bộ sẽ thực hiện:
 - Giữ thông tin thiết bị đầu cuối một cách an toàn
 - Kích hoạt hệ thống 2FA để tạo mật khẩu cấp hai.
- Giải pháp này có thể được triển khai trong phạm vi công cộng, thậm chí trong một hệ thống mạng riêng với một cuộc gọi API bên thứ ba.

2.1. Blockchain có thể biến đổi 2FA như thế nào



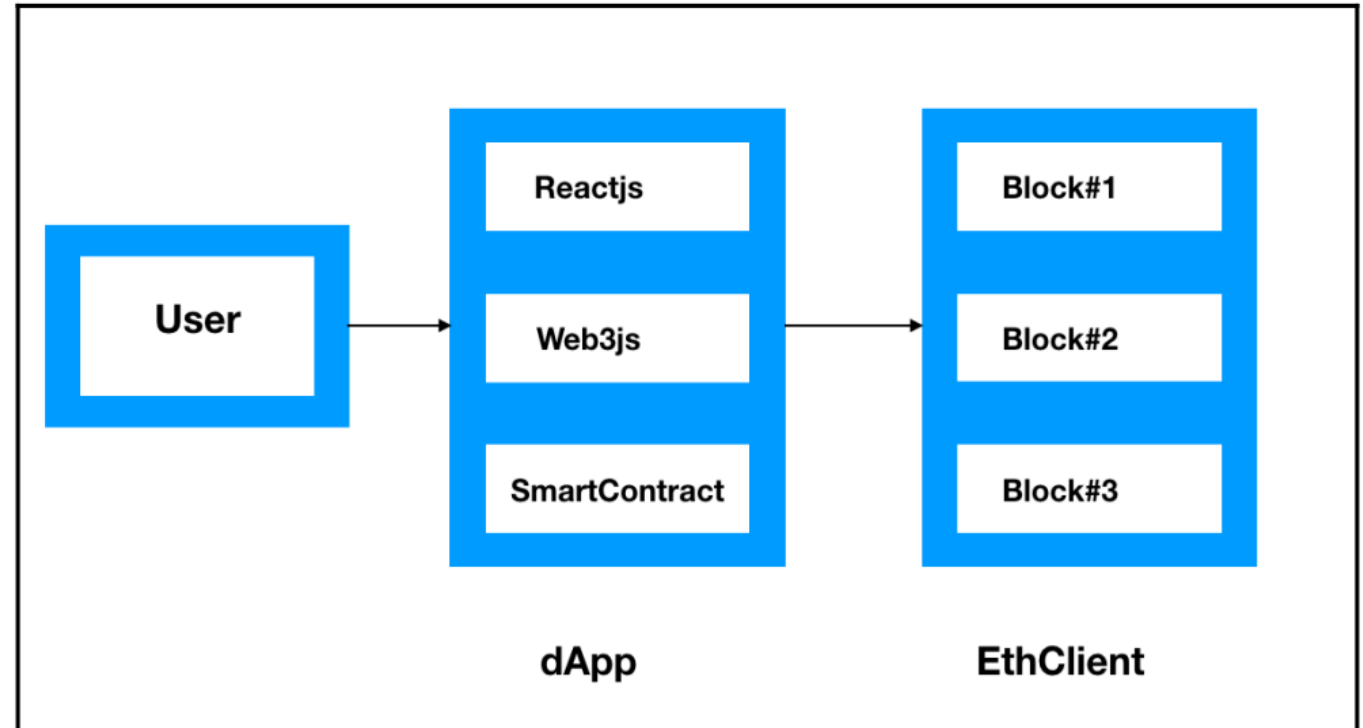
2.2. Kiến trúc giải pháp

- Blockchain vẫn đang trong giai đoạn thử nghiệm.
- Ví dụ, về việc sử dụng Ethereum để khởi tạo hệ thống 2FA, cho phép ứng dụng được lập trình với một smart contract.
- Trong sơ đồ sau, luồng cơ bản giữa người dùng, ứng dụng web và kho lưu trữ dựa trên Ethereum được mô tả như sau:



2.2. Kiến trúc giải pháp

- Người dùng truy cập cổng thông tin web và nhập thông tin đăng nhập đầu tiên.
- Ứng dụng web sẽ liên lạc với kho lưu trữ dựa trên Ethereum để tạo OTP và chia sẻ với người dùng.
- Cuối cùng, người dùng nhập OTP và có quyền truy cập vào ứng dụng web.



3. Kết luận

- Trong chương này, chúng ta đã tìm hiểu về giải pháp 2FA, một trong những biện pháp an ninh quan trọng nhất hiện nay.
- Tuy nhiên, kho lưu trữ trung tâm có thể gặp nguy cơ bị xâm nhập bởi các cuộc tấn công mạng tinh vi.
- Chúng ta đã hiểu được cách Blockchain giúp phân tán cơ sở dữ liệu trên nhiều nút và giúp giảm nguy cơ bị xâm nhập dữ liệu.
- Hợp đồng thông minh Ethereum là một thành phần tuyệt vời để hoàn thiện một hệ thống 2FA, cung cấp sự linh hoạt để lập trình toàn bộ hệ thống.

